

SBSEG 2026 · BÚZIOS, RJ · 1 A 4 DE SETEMBRO

OSCensus

Um censo com múltiplos scanners das
imagens-base Linux do Docker Hub



Cristhian Kapelinski · Diego Kreutz
AI Horizon Labs · UNIPAMPA
Trilha principal · artigo curto



AI HORIZON
LABS
Explorando Novas Fronteiras da Inteligência Artificial



92%

**dos profissionais de TI
usam contêiner · 2025**

**The 2025 Docker State of
Application Development
Report**



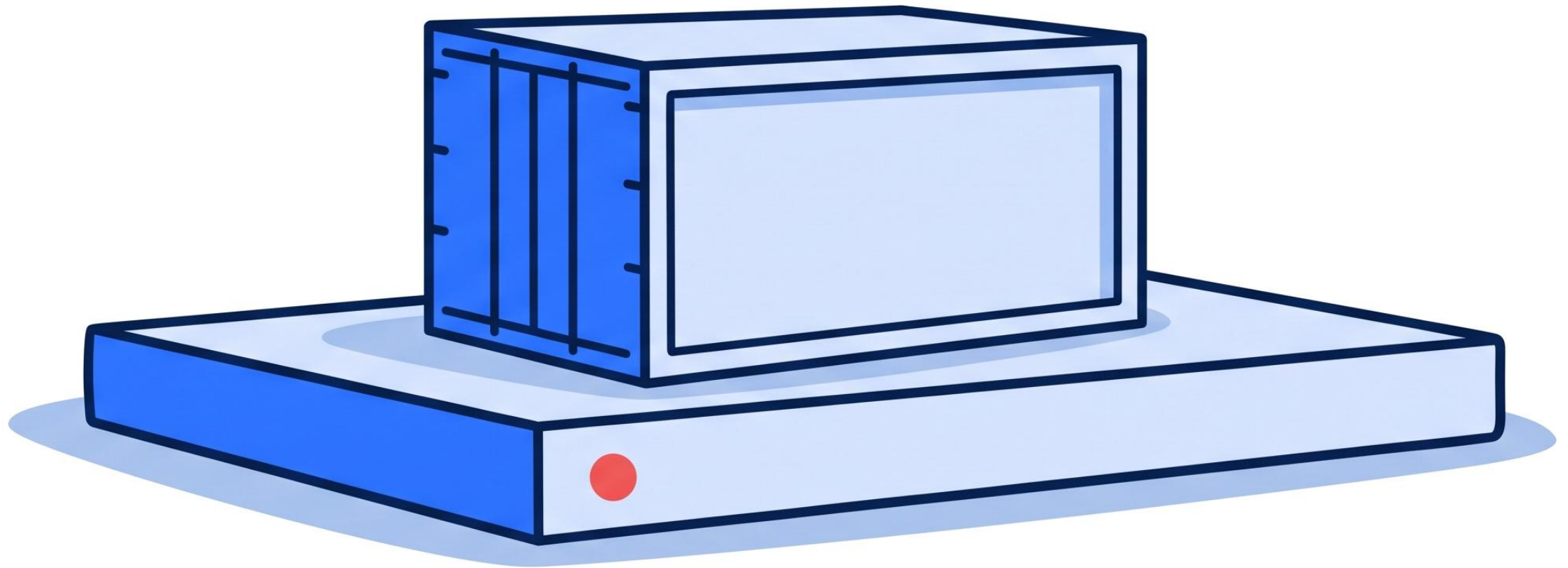
8,3 milhões

**repositórios no Docker
Hub · 2021**

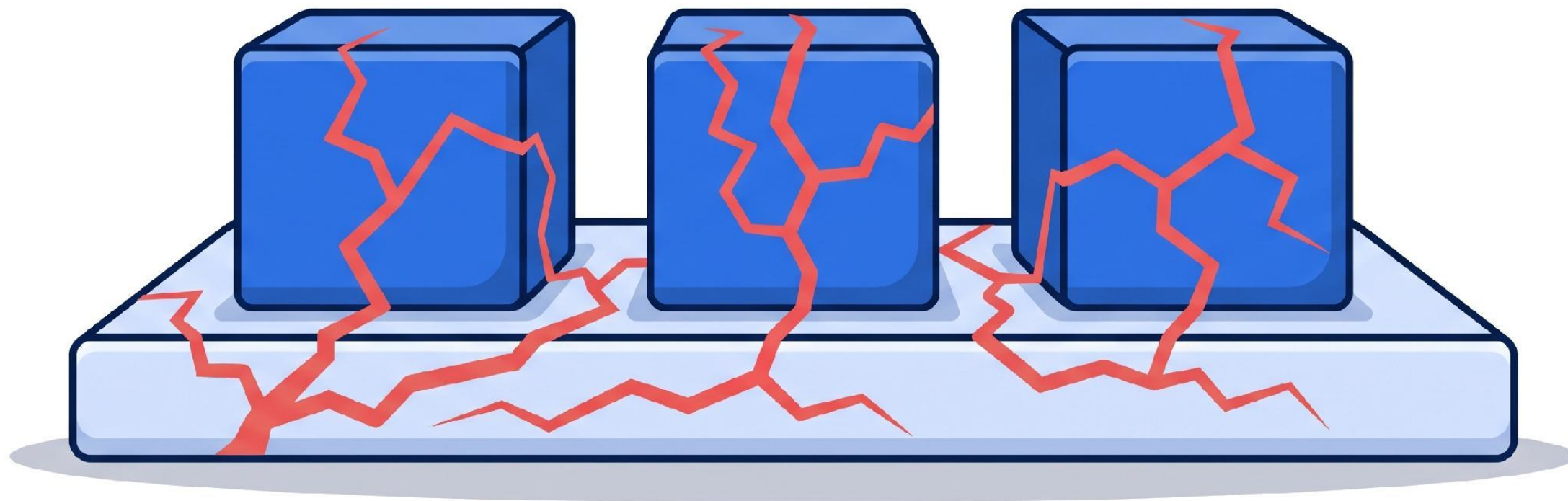
**Docker Index Shows Continued
Massive Developer Adoption
and Activity to Build and Share
Apps with Docker**



O PROBLEMA



O PROBLEMA



48.185

CVEs 2025

2025 CVE Data Review

January 1, 2026

2025 set a new baseline with **48,185 published CVEs**. While the sheer volume is



Ninguém juntou base e bateria

Família	Imagens	Base	Compar
Censos de escala	até 2,2 mi	×	^a ×
Comparação de scanners	até 52.895	×	✓
Foco na base	261	✓	×
Este trabalho	5.606	✓	✓

01

Censo



0 corpus

20

distribuições · linux/amd64

21

repositórios · rockylinux usa dois

5.606

imagens únicas na fila

A bateria

Inventário de pacotes

2



Syft



cdxgen

Vulnerabilidades

4



Trivy



Grype



OSV-Scanner



clair

Configuração

2



Dockle

checkov

A bateria

Segredos

4



TruffleHog

detect-secrets



Gitleaks



Whispers

Malware e IOC

2



ClamAV



YARA-Hunter

A análise tem cinco etapas

- 1 Resolver** a tag até o digest amd64
- 2 Fixar** a imagem naquele digest
- 3 Exportar** o sistema de arquivos em um tar
- 4 Analisar** o tar com as catorze ferramentas
- 5 Registrar** as saídas de cada ferramenta

A análise tem cinco etapas

- 1 Resolver a taq até o digest amd64
- 2 Fixar a imagem naquele digest
- 3 Exportar o sistema de arquivos em um tar
- 4 Analisar o tar com as catorze ferramentas
- 5 Registrar as saídas de cada ferramenta

A análise tem cinco etapas

- 1 Resolver** a tag até o digest amd64
- 2 Fixar** a imagem naquele digest
- 3 Exportar** o sistema de arquivos em um tar
- 4 Analisar** o tar com as catorze ferramentas
- 5 Registrar** as saídas de cada ferramenta

A análise tem cinco etapas

- 1 Resolver** a tag até o digest amd64
- 2 Fixar** a imagem naquele digest
- 3 Exportar** o sistema de arquivos em um tar
- 4 Analisar** o tar com as catorze ferramentas
- 5 Registrar** as saídas de cada ferramenta

A análise tem cinco etapas

- 1 Resolver** a tag até o digest amd64
- 2 Fixar** a imagem naquele digest
- 3 Exportar** o sistema de arquivos em um tar
- 4 Analisar** o tar com as catorze ferramentas
- 5 Registrar** as saídas de cada ferramenta

Hardware

1× Ryzen 5 8600G, 6 núcleos, 32 GB

4× Core i7-9700, 8 núcleos, 32 GB

147h de máquina

0 corpus final

5.606 imagens únicas na fila

5.142 relatórios produzidos

464 imagens ficaram sem relatório

02

Os achados



A base escolhida muda os achados

Média de críticas e altas por imagem

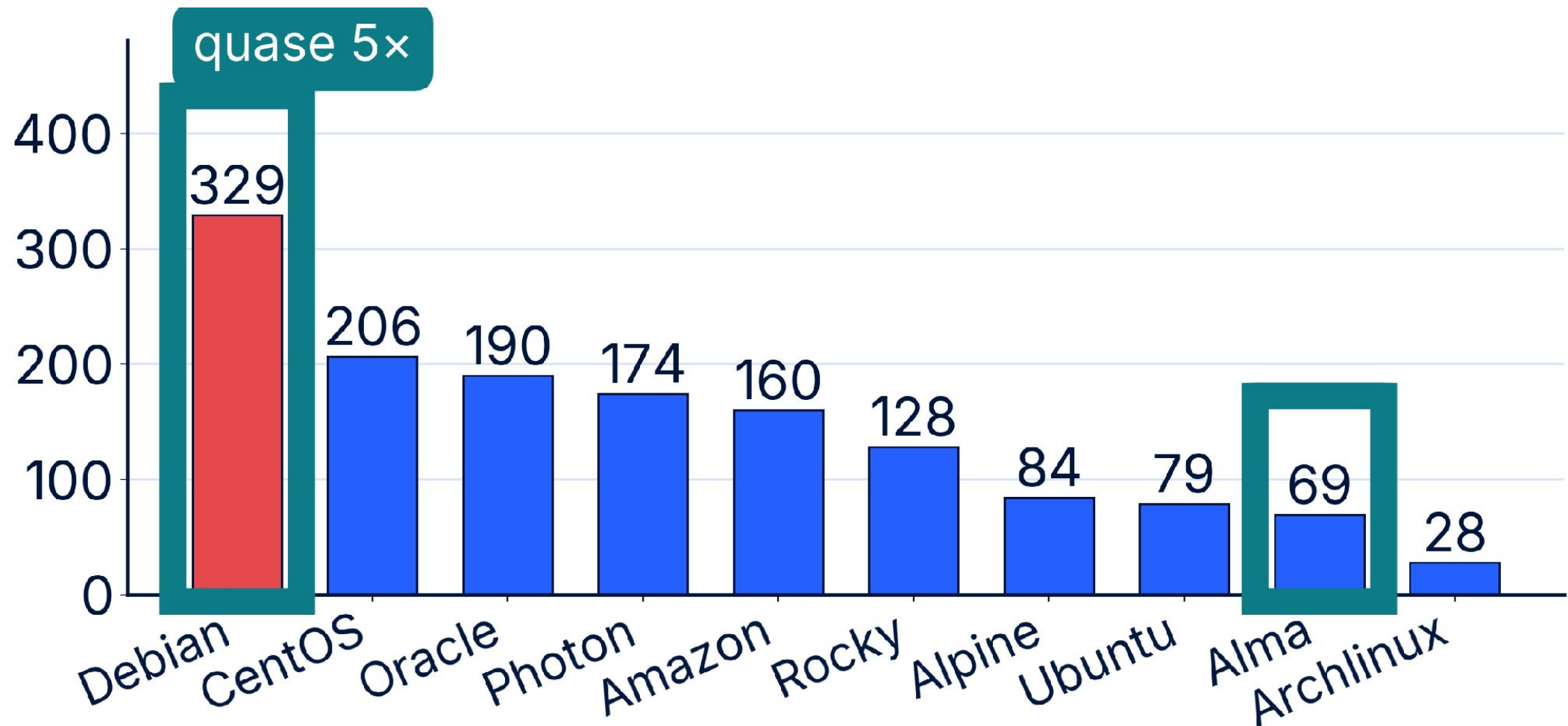
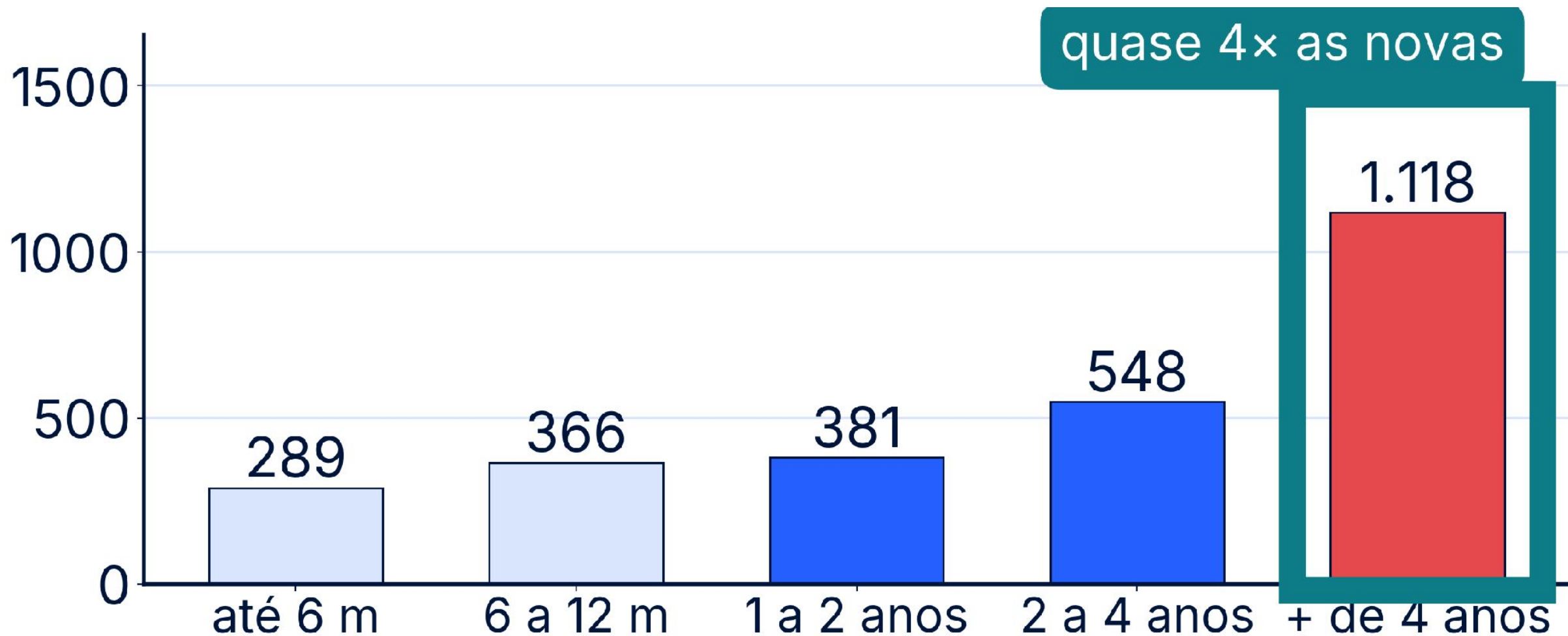


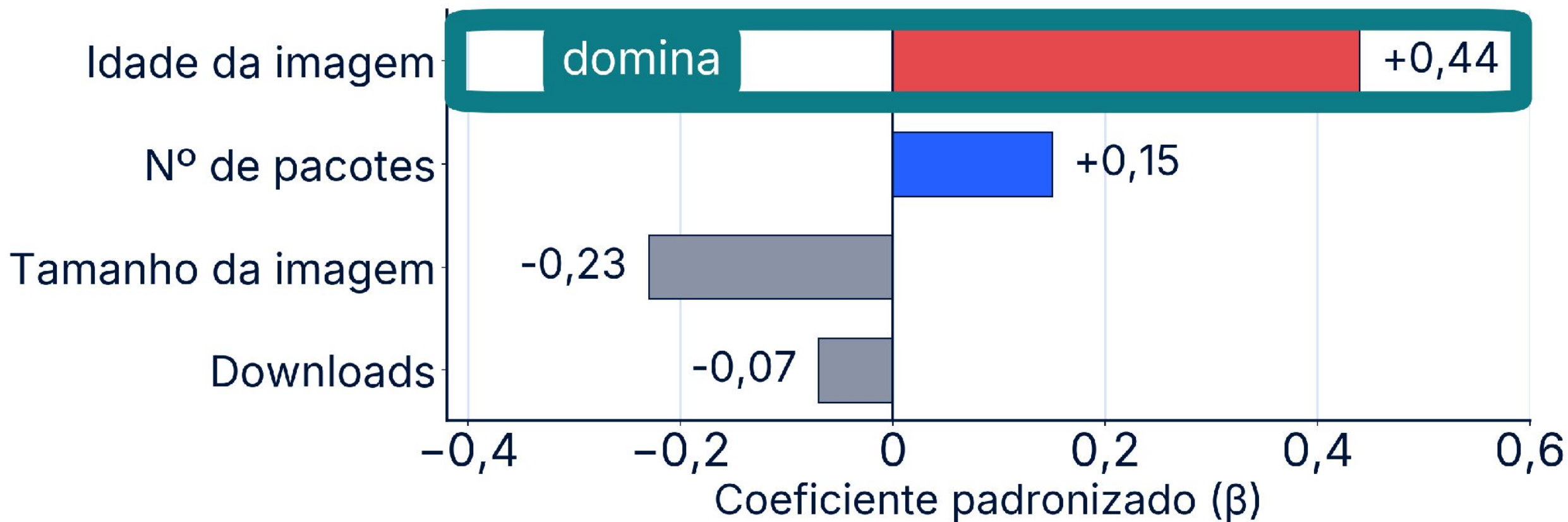
Imagem antiga acumula mais achados

Vulnerabilidades por faixa de idade



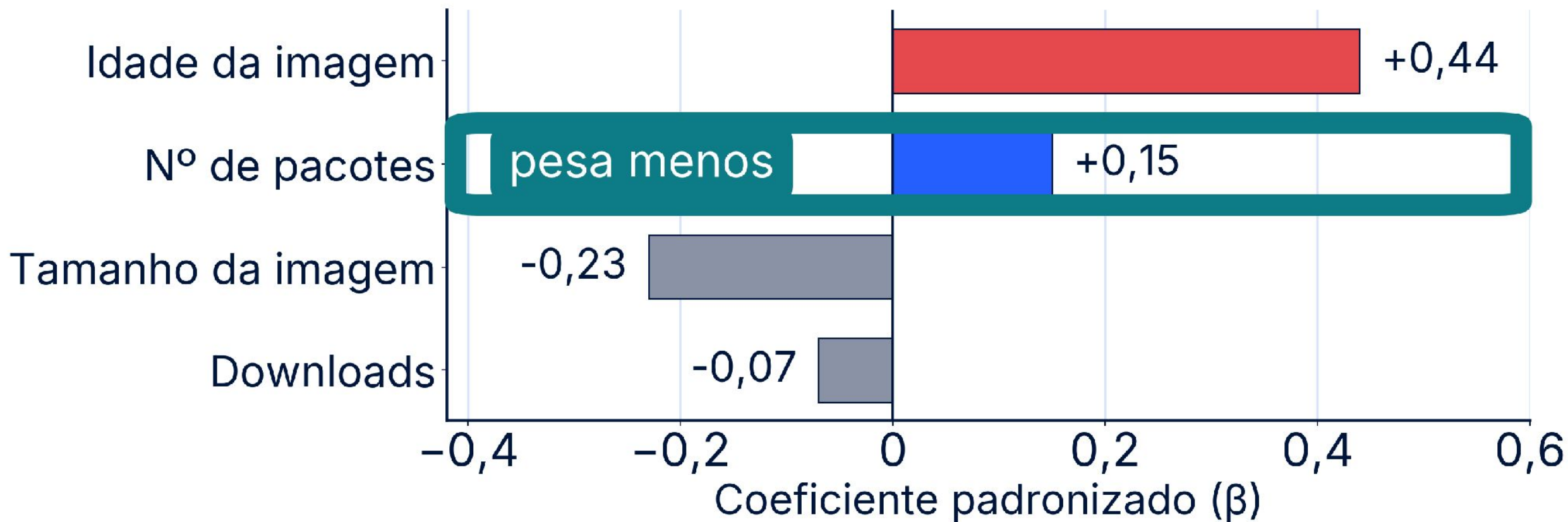
Preditores

Coeficiente padronizado de cada preditor



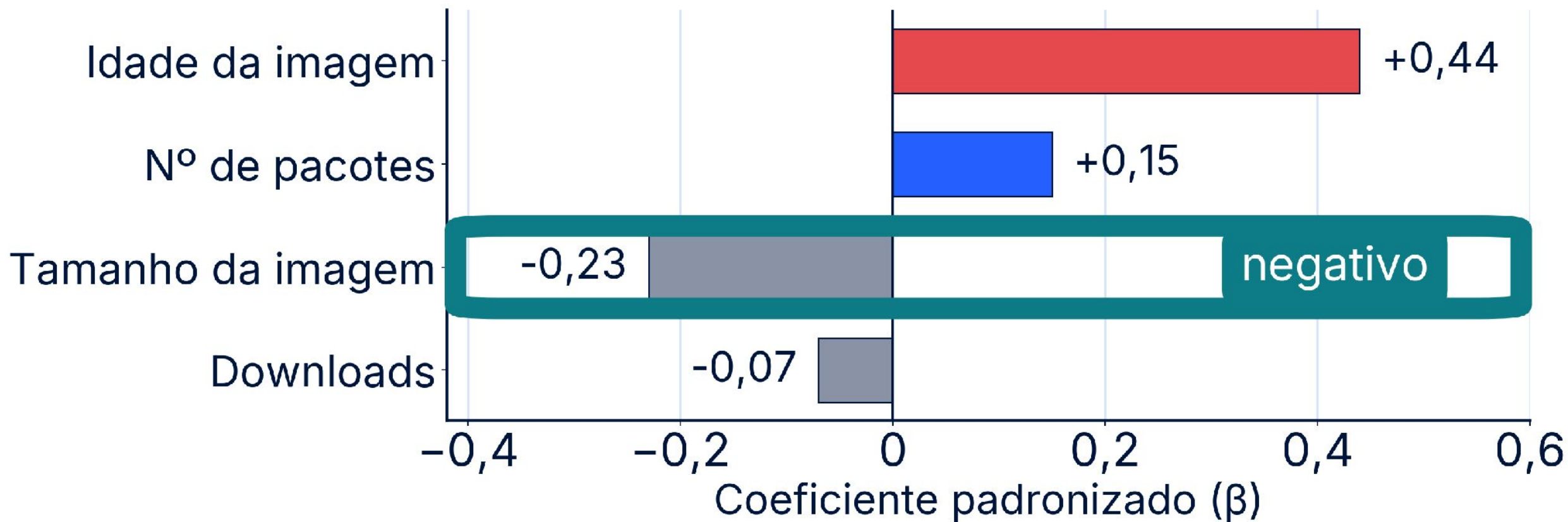
Preditores

Coeficiente padronizado de cada preditor



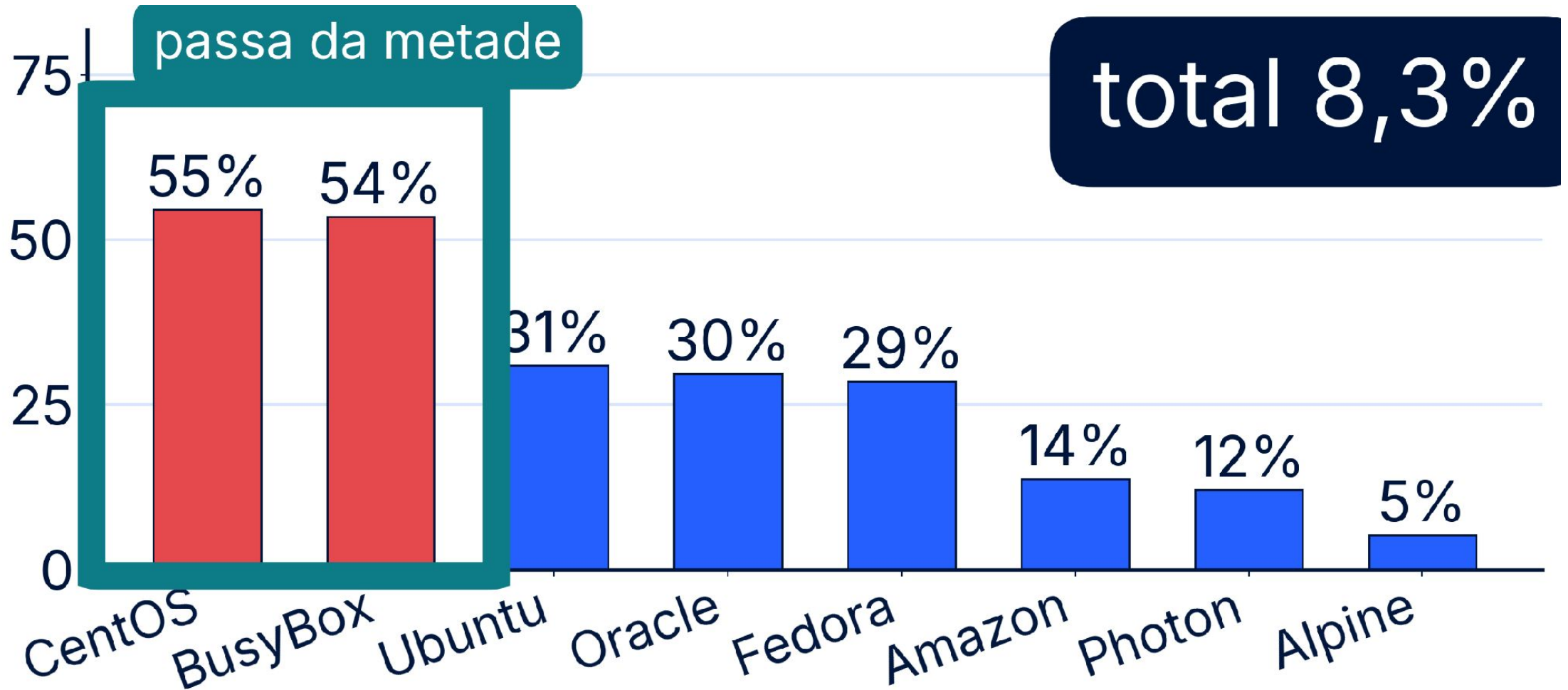
Preditores

Coeficiente padronizado de cada preditor



Mais da metade, no centos e busybox

Imagens que o Docker Engine atual recusa



Os scanners concordam pouco

0,36 Trivy e Grype, o par que mais concorda

0 a 0,13 os demais pares

83,4% das imagens, positivo em segredo

84,7% das imagens, positivo em malware

0 verdadeiros positivos em 1.100 revisões à mão

Dockle e Checkov acusam

100%

das imagens em que rodaram

Uma imagem-base é um sistema de arquivos estático, sem serviço em execução.

03

Conclusões



Contribuição

- **5.606 imagens-base**
- **20 distribuições Linux**
- **14 ferramentas, cinco eixos**
- **Conjunto de dados publicado**

Resultados

- **Idade pesa mais que pacotes**
- **Tamanho aponta ao contrário**

Conclusões

- **Atualização recente**
- **Tamanho e popularidade não predizem**

Limitações

- **linux/amd64**
- **Pacotes e vulnerabilidades não conferidos à mão**



Obrigado!

Perguntas são bem-vindas

AUTOR DE CONTATO

Cristhian Kapelinski

`cristhianavila.aluno@unipampa.edu.br`



Artigo



Artefato



AI Horizon



Apoio



FAPERGS

Fundação de Amparo à Pesquisa do Estado do Rio Grande do Sul



Slides de reserva

Material de apoio: achados por distribuição, contagem e validações manuais.

Achados por distribuição (1 de 3)

Debian **329** $n = 2.641 \cdot dp$ 375

CentOS **206** $n = 10$, frágil

OracleLinux **190**

Photon **174**

Média de achados críticos e altos por imagem

Achados por distribuição (2 de 3)

AmazonLinux

160

RockyLinux

128

library/rockylinux

Alpine

84

Ubuntu

79

Achados por distribuição (3 de 3)

AlmaLinux

69

Archlinux

28

Fedora, Kali, Mageia e Tumbleweed quase não têm

Como contamos as vulnerabilidades

1.025.210 pares somados
Soma dos motores, com severidade.

710.739 pares deduplicados
Cada CVE, uma vez por imagem.

0,86 de correlação de Spearman
O ranqueamento quase não muda.

1,44 vez de inflação por sobreposição

Dentro da distribuição, pacotes importam

- No Ubuntu o coeficiente de pacotes é 0,53; no AlmaLinux, 0,65
- É a variação ENTRE distribuições que domina o agregado
- BusyBox: um pacote e um punhado de achados
- Debian: mais críticas que o Mageia, com menos pacotes

Como as detecções foram validadas

- Amostras estratificadas de semente fixa (semente 42)
- 1.100 de 26.892 detecções de segredo
- 1.100 de 13.348 correspondências do YARA-Hunter
- Todas falsas nos dois eixos; limite de Wilson de 0,35%

O que o trabalho não sustenta

- Repositório pequeno dá tendência, não estimativa
- Só sistemas operacionais, em linux/amd64
- Os achados de pacote não foram conferidos à mão
- Tags flutuantes e bases atualizadas impedem replay exato

Quanto cada ferramenta rodou (1 de 2)

	Rodou	Falhou
Grype	5.142	—
Checkov	5.140	2
TruffleHog	5.140	2
Gitleaks	5.140	2
detect-secrets	5.140	2
ClamAV	5.140	2
YARA-Hunter	5.140	2

Quanto cada ferramenta rodou (2 de 2)

	Rodou	Falhou
Syft	5.139	3
Dockle	5.139	3
cdxgen	5.138	4
Trivy	5.014	128
OSV-Scanner	4.070	1.072
Clair	2.357	2.785
Whispers	1.294	3.848

74,8% a imagem do scanner saiu do Hub

3.848 de 5.142 execuções

54,2% rate limit do Docker Hub

2.781 das 2.785 falhas

20,8% sem fonte de pacote no tar

1.050 das 1.072 falhas

2,5% cache em uso por outro processo

122 das 128 falhas

As outras dez

$\leq 0,1\%$ erro do daemon no overlay2

2 a 4 imagens cada